CYBER INTELLIGENCE AND INFORMATION SECURITY

SAPIENZA
UNIVERSITÀ DI ROMA

Contratto

Analisi dei requisiti di rotazione di chiavi crittografiche utilizzate in processi estrazionali

Deliverable finale della attività A1:

Definizione della frequenza di rotazione delle chiavi crittografiche

Roma, 20 Maggio 2026

Il responsabile scientifico per CIS

Prof. Paolo Giulio Franciosa

Via Ariosto 25, 00185 Roma
T (+39) 06 77274024 F (+39) 06 77274131
codice fiscale 80209930587
partita IVA 02133771002
http://www.cis.uniroma1.it/

Definizione della frequenza di rotazione delle chiavi crittografiche

Vengono considerati i criteri per la definizione delle politiche di rotazione delle chiavi crittografiche RSA-PKCS#1 v1.5 utilizzate in modalità firma per la generazione delle estrazioni pubbliche. Il contesto operativo è caratterizzato da volumi di utilizzo elevati e da requisiti stringenti di impredicibilità, uniformità e ripetibilità dei risultati, in assenza di meccanismi di auditing esterno.

L'analisi prende in esame tre fattori determinanti: la superficie d'attacco cumulativa che si accumula nel tempo con schemi fault e side-channel ad alti volumi; il vincolo di ripetibilità, che impone la conservazione sicura e permanente delle chiavi dismesse per consentire la verifica storica delle estrazioni; e l'assenza di auditing, che trasferisce interamente sulla trasparenza crittografica del processo il peso della fiducia nel sistema.

Dall'interazione di questi fattori si ricava una raccomandazione di rotazione ordinaria con cadenza di 30 giorni, coerente con le indicazioni di NIST SP 800-57 Part 1 Rev. 5, e si definiscono le condizioni che richiedono una rotazione straordinaria immediata indipendentemente dal ciclo programmato. Maggiori dettagli sono forniti nel punto 3. del presente documento.

Il deliverable è organizzato in tre brevi parti: definizione contesto (1.), elementi di rilievo che impattano su rotazione chiavi (2.) e frequenze raccomandate (3.).

1. Contesto e vincoli

Fondamentale riepilogare i fattori che determinano i casi in esame.

- Algoritmo: RSA con PKCS#1 v1.5
- Uso: firma per generazione estrazioni pubbliche (non cifratura)
- Volume di utilizzo:
  - 10eLotto frequente: 288 operazioni/giorno
  - 10eLotto immediata: fino a 160.000 operazioni/giorno
  - MillionDay: 2 operazioni/giorno
  - Fai3 e Fai4: 288 operazioni/giorno
- Requisiti: risultati impredicibili, uniformi, ripetibili
- Auditing: assente

2. Fattori critici che influenzano la rotazione

2.1. Vulnerabilità note di RSA-PKCS#1 v1.5 in firma

Benché PKCS#1 v1.5 per la firma sia considerato sicuro, esso presenta rischi specifici quando impiegato ad alti volumi, perché gli attacchi di fault/side-channel sono statisticamente più praticabili con milioni di osservazioni: con 160.000 firme/giorno, circa 58 milioni/anno, la superficie d'attacco non è trascurabile [1] . Nessuno standard attuale vieta esplicitamente l'utilizzo di PKCS#1 v1.5 per la firma, ma NIST SP 800-131A Rev. 2 spinge verso PSS (PKCS 2.2).

2.2. Il requisito di ripetibilità

La ripetibilità implica che l'input deterministico della firma debba essere conservato, la chiave privata usata in quel momento e la corrispondente chiave pubblica debbano essere recuperabili per verificare, entro i limiti temporali prestabiliti, la correttezza della firma. In particolare, la rotazione crea una discontinuità: occorre mantenere le chiavi scadute per la verifica storica. Ne segue che nel processo di rotazione le chiavi crittografiche precedentemente usate non devono essere eliminate, bensì archiviate in modo sicuro e immutabile.

2.3. Assenza di auditing

L'assenza di auditing sposta il peso della fiducia interamente sulla trasparenza crittografica del processo. Questo suggerisce che le chiavi pubbliche siano pubblicate su registro immutabile (blockchain, CT log,[2] o simile) prima dell'uso. I periodi di validità brevi e ben documentati aumentano la verificabilità pubblica. **La rotazione frequente riduce la finestra temporale di un'eventuale compromissione non rilevata**.

---

[1] Con il crescere del numero di osservazioni si può calcolare la media temporale dei tempi per le operazioni di firma. Il rumore casuale converge a zero per la legge dei grandi numeri e il segnale sistematico legato alla chiave privata emerge. Questo è il principio di attacchi come Remote Timing Attack dimostrati su RSA reale (Brumley & Boneh, 2003, su OpenSSL via rete).

[2] V., ad es., https://www.digicert.com/it/faq/public-trust-and-certificates/what-are-ct-logs

3. Frequenza di rotazione

Per tutti i tipi di estrazione la **postura di sicurezza** domina sulla **componente crittografica**. Quest'ultima, nel caso della tipologia di estrazione con frequenza maggiore (10eLotto in modalità immediata), suggerirebbe un periodo di rotazione nell'ordine di un anno o più; negli altri casi il periodo potrebbe essere più lungo. Indipendentemente dal numero di estrazioni, una adeguata postura di sicurezza richiede una misura che è indipendente dal numero di estrazioni e che prevede una limitazione del tempo che ha a disposizione un attaccante interno per sfruttare una chiave privata compromessa. Un buon bilanciamento fra prudenza e onere di gestione suggerisce un periodo di rotazione dell'ordine del mese.

Ciò premesso, si raccomanda una **rotazione primaria ogni 30 giorni**. La tabella che segue riassume le motivazioni che hanno prodotto la raccomandazione.

Criterio	Motivazione
Volume cumulativo	≤ 5M firme/ciclo rimane entro soglie conservative
Esposizione temporale	Finestra di compromissione limitata a 30gg nel caso peggiore
NIST SP 800-57 Part 1 Rev. 5	Raccomanda periodi di attivazione brevi per chiavi con alto utilizzo
Assenza di auditing	Rotazione frequente compensa parzialmente la mancanza di controllo esterno
Gestione operativa	Bilanciamento tra sicurezza e onere di gestione

Rotazione straordinaria: **immediata**

Si raccomanda che avvenga immediatamente e indipendentemente dal ciclo raccomandato nei casi descritti nella tabella che segue

1.	Sospetto o evidenza di compromissione della chiave privata
2.	Compromissione dell'HSM o dell'ambiente di firma
3.	Pubblicazione di nuove vulnerabilità critiche su RSA/PKCS#1 v1.5
4.	Cambio del personale con accesso alla chiave
5.	Anomalie statistiche nei risultati delle estrazioni (includono vincite cospicue o ripetute)

Roma, 20 Maggio 2026

Il responsabile scientifico per CIS

(Paolo Giulio Franciosa)